

PRODUCT REQUIREMENTS DOCUMENT

Candor

Anonymous Q&A Platform

Companion specification to the Candor Product Case Study

Author	Ashutosh Mohanty — Product Lead
Date	July 2026
Document Type	Product Requirements Document (PRD)
Live Product	candor-h0aw.onrender.com

1. Document Control

Field	Detail
Document Title	Candor — Product Requirements Document
Version	1.0
Status	Final — Portfolio Release
Author / Owner	Ashutosh Mohanty (Product Lead)
Companion Document	Candor Product Case Study, July 2026 — background, market context, personas detail, technical rationale, and lessons learned live there and are not repeated here.
Repository	github.com/AshutoshMohanty07/Candor
Live Environment	candor-h0aw.onrender.com

2. Executive Summary

This PRD defines the product requirements and functional specification for Candor, an anonymous Q&A web application. It is a companion to the Candor Product Case Study and intentionally does not restate the problem background, market research, competitive analysis, product-decision rationale, or lessons learned already documented there.

This document instead specifies what the product must do: objectives, scope, user flows, feature-level requirements, functional and non-functional requirements, acceptance criteria, risks, and the release plan — in the structured format a product team would use to build, QA, and extend the system.

Ownership note

The product was built using AI-assisted software development. Product ideation, MVP definition, scope decisions, feature prioritization, UI/UX direction, deployment coordination across three platforms, end-to-end QA, and all documentation were owned directly by the author. Implementation was directed and reviewed with AI assistance rather than hand-written independently.

3. Product Objectives

Objectives define what the v1 system must achieve. Market rationale and vision narrative are covered in the Case Study; this section states them as testable product objectives.

ID	Objective
O-1	Ship a complete, live, independently deployable anonymous-messaging loop: public send → private inbox → public reply.
O-2	Guarantee that every inbox-owning action (read, reply, ignore, report) can only be performed by a verified owner.

O-3	Keep the anonymous-sending experience login-free and frictionless for the visitor.
O-4	Exclude, by design, any sender de-anonymization or paywalled “reveal” mechanic.
O-5	Provide the account owner with baseline safety controls (report, block, content filter) without manual-moderation dependency at launch scale.

4. Product Scope

In Scope — v1

- Owner onboarding and public-username claim flow
- Public, no-login anonymous message submission
- Private, token-gated inbox with reply / ignore / report actions
- Reply-as-public-card sharing flow
- In-product Insights (message volume, reply rate, activity)
- Settings: content filter toggle and block list
- Rate limiting on the public send endpoint

Out of Scope — v1

- Sender identity reveal, in any paid or free form
- Push notifications
- Automated content moderation beyond manual report
- Native mobile application
- Automated test suite (currently manual QA only)

5. User Personas

Full persona detail lives in the Case Study. Summarized here only as context for the flows and requirements below.

Persona	Primary Need	Primary Surface
Priya — Casual Sharer	Low-friction way to see what her circle says	Owner inbox (light use)
Devika — Creator	High-quality reply-card sharing flow	Reply → public card
Rahul — Curious Sender	Frictionless anonymous sending, no account	Public send page

6. Core User Flows

Flow A — Anonymous Visitor Send

1 Open shared link	2 Load public send page	3 Compose message	4 Submit (rate-limit checked)	5 Message stored	6 Confirmation shown
------------------------------	-----------------------------------	-----------------------------	---	----------------------------	--------------------------------

Flow B — Owner Manage Inbox

1 Open owner app	2 Token-authenticated inbox load	3 Review message	4 Choose: Reply / Ignore / Report	5 Action processed	6 Insights updated
----------------------------	--	----------------------------	---	------------------------------	------------------------------

7. Feature Specifications

Each feature below is specified independently of the narrative decisions covered in the Case Study, in the standard Objective / User Value / Requirements / Out of Scope / Acceptance Criteria format.

7.1 Public Profile & Shareable Link

Objective	Let an owner claim a unique public username that becomes their shareable Candor link.
User Value	A memorable, personal link the owner can distribute anywhere to start receiving messages.
Requirements	- Username must be validated for availability in real time during claim. - Allowed characters: letters, numbers, underscores. - Username is editable post-creation from Settings. - The claimed username forms the public URL path (candor.app/{username}).
Out of Scope	Custom domains and vanity link purchasing.
Acceptance Criteria	- An available username can be claimed and resolves to a working public send page. - A taken username is rejected with a clear inline message. - Changing the username updates the resolvable public link without breaking the owner's session.

7.2 Anonymous Message Sending

Objective	Allow any visitor to send a message to an owner's inbox with zero account creation.
User Value	Removes the single biggest friction point in the category: senders participate with no signup.
Requirements	- Public send page requires no authentication. - Message requires non-empty text content within a defined character limit.

	- Endpoint is rate-limited to 10 requests per minute per IP address. - Sender receives a confirmation state after successful send, with no identifying data collected.
Out of Scope	Message attachments (images, audio, links) and multi-message threads.
Acceptance Criteria	- A visitor can submit a message without logging in or registering. - A submitted message appears in the correct owner's inbox only. - Requests exceeding the rate limit are rejected rather than queued or silently dropped.

7.3 Private Inbox & Access Control

Objective	Give the owner a private, authenticated view of received messages, inaccessible to anyone else — including someone who knows the public username.
User Value	Trust that only the account owner can ever read or act on their inbox.
Requirements	- Every inbox route requires a private owner token issued at signup, passed via request header. - Token must be validated against the specific resource being accessed on every request. - Requests without a valid token return 401/403 rather than partial or empty success. - Token is never derivable from, or equal to, the public username.
Out of Scope	Multi-device token sync UI and token rotation/reset self-service (planned post-v1).
Acceptance Criteria	- An authenticated owner can view only their own messages. - A request with a missing, invalid, or another owner's token is rejected with 401/403. - No inbox action succeeds silently without a valid token.

7.4 Reply as Public Card

Objective	Let an owner turn a received message into a shareable public reply card.
User Value	Turns anonymous input into publishable content, supporting the Creator persona's repeat-use pattern.
Requirements	- Owner can compose a reply to any inbox message. - Reply is rendered as a shareable card suitable for external platforms. - Original anonymous message text is preserved on the card without exposing sender identity.
Out of Scope	Native cross-posting/API integration with external social platforms.
Acceptance Criteria	- A reply successfully attaches to its source message and is retrievable as a public card. - The reply-rate metric on Insights reflects the action immediately.

7.5 Ignore & Report Actions

Objective	Give the owner a lightweight way to dismiss unwanted messages and flag abusive ones.
User Value	Keeps inbox management fast, and gives the owner a first line of defense against abuse.
Requirements	• “Ignore” permanently deletes the message from the inbox (no archive/undo). • “Report” flags the message for review and removes it from the active inbox view. • Both actions are owner-token gated, identical to reply.
Out of Scope	A moderation review queue or automated moderation pipeline.
Acceptance Criteria	• Ignoring a message removes it from the inbox and it does not reappear. • Reporting a message is recorded and removed from the active view.

7.6 Insights Dashboard

Objective	Give the owner visibility into their own activity without exposing sender-level data.
User Value	Lightweight feedback loop that reinforces engagement without vanity-metric inflation.
Requirements	• Surface message volume (weekly, all-time), reply count, and reply rate. • All figures computed from the owner's own real data — no placeholder or simulated values.
Out of Scope	Cross-owner leaderboards or public-facing stats.
Acceptance Criteria	• Insights values update after each new message, reply, ignore, or report. • An owner with zero activity sees an accurate empty/zero state, not an error.

7.7 Settings: Content Filter & Block List

Objective	Give the owner baseline, self-serve safety controls.
User Value	Reduces exposure to unwanted or abusive senders without waiting on manual moderation.
Requirements	• Content filter toggle to auto-hide messages matching flagged content patterns. • Block list to prevent further messages from a reported source where technically identifiable. • Both controls are owner-scoped and editable from Settings at any time.
Out of Scope	Configurable/custom filter rules and third-party moderation API integration.
Acceptance Criteria	• Toggling the content filter changes inbox filtering behavior on the next message received.

- A blocked source cannot deliver further messages to that owner's inbox.

8. Functional Requirements

ID	Requirement	Priority
FR-01	System shall allow username claim with real-time availability check.	Must
FR-02	System shall serve a public, unauthenticated send page per valid username.	Must
FR-03	System shall persist each anonymous message against the correct owner record.	Must
FR-04	System shall require a valid owner token on every inbox read/write route.	Must
FR-05	System shall return 401/403 for any inbox action without a valid token.	Must
FR-06	System shall support reply, ignore, and report actions per message.	Must
FR-07	System shall rate-limit the public send endpoint to 10 requests/minute/IP.	Must
FR-08	System shall compute and display message volume, reply count, and reply rate.	Should
FR-09	System shall provide a content-filter toggle and block list in Settings.	Should
FR-10	System shall generate a shareable public reply card per replied message.	Should

9. Non-Functional Requirements

Category	Requirement
Security	Owner authentication via a private, non-derivable token (Python secrets module); every sensitive route validates token-to-resource ownership.
Abuse Prevention	Public send endpoint rate-limited at 10 requests/minute/IP to reduce spam exposure on the one unauthenticated route.
Availability	Deployed on free-tier hosting (Render + Aiven); a cold-start delay of roughly 30–50 seconds after 15 minutes of inactivity is an accepted trade-off for this stage.
Deployability	Containerized (Docker), auto-deployed on push to the main branch.
Usability	Public send flow requires no account and no more than one screen to complete.
Data Integrity	Normalized relational schema (users, messages, replies) enforced via foreign keys on MySQL.
Maintainability	Currently validated through manual end-to-end QA; automated unit/integration test coverage is a near-term addition (see Roadmap).

10. Acceptance Criteria — v1 Definition of Done

System-level criteria a build must meet before it is considered release-ready, in addition to the per-feature criteria in Section 7.

- A message sent from the public link is retrievable, unaltered, in the correct owner's inbox.
- Reply, ignore, and report each execute correctly and are reflected immediately in Insights.
- No inbox route returns data or performs an action without a valid, matching owner token.
- The public send endpoint enforces its rate limit under repeated requests from a single source.
- The Share screen displays the application's real, live URL — not a placeholder.
- The full loop is reproducible end-to-end on the production deployment, not only in a local environment.

11. Risks & Assumptions

Risks

Risk	Mitigation / Notes
Free-tier cold starts degrade first-touch experience.	Accepted for portfolio stage; paid tier is the fix for a real launch.
No automated test suite; regressions rely on manual QA.	Prioritized in Release Plan Phase 2.
Manual-only report review has no moderation SLA.	Acceptable at current scale; flagged for Phase 3.
Single-region, free-tier database has no documented backup/restore process.	Out of scope for v1; revisit before any real user data is handled at scale.

Assumptions

- Senders and owners already know each other via an existing social graph; discovery is not part of this product.
- A public username is acceptable as a distribution mechanism and is never treated as an authentication credential.
- Message volume at this stage remains within free-tier hosting and database limits.

12. Release Plan

1 Phase 1: MVP (Shipped)	2 Phase 2: Hardening (Tests, monitoring)	3 Phase 3: Growth (Notifications, custom domain)
------------------------------------	--	--

Phase	Focus	Status
Phase 1	Core send/inbox/reply loop, access control, live deployment	Shipped
Phase 2	Automated tests, expanded moderation, reliability hardening	Planned
Phase 3	Push notifications, custom domain, native mobile evaluation	Planned

13. Future Roadmap

Detailed rationale is in the Case Study; listed here only as forward-looking scope for planning purposes.

- Automated unit and integration test coverage
- Push notifications for new messages
- Expanded automated content moderation beyond manual report
- Custom domain, replacing the current hosting subdomain
- Native mobile wrapper, if usage patterns justify it